攻撃者視点で考えるセキュリティ -1-

岡山大学環境生命自然科学学域
情報セキュリティ工学研究室　助教　小寺雄太

法令と倫理

本講座では様々な攻撃手法やツールについて触れることがある．受講者は以下を必ず念頭におくこと．

- 社会で定められた「不正アクセス禁止法」や「不正指令電磁的記録」などの法令を遵守し，あらゆる状況下においても適切に技術を扱うこと
- また，法令に抵触しない場合においても，日本技術士会 技術士倫理綱領などを参考に倫理的かつ適切な判断を行うこと

Outline

- 攻撃者たちの目的と標的

- セキュリティの敗北史：ケーススタディ
  - KADOKAWAグループに対する大規模攻撃
  - 徳島県 半田病院に対するランサムウェア攻撃

攻撃者たちの目的と標的

- 金銭の要求
  - 法人を標的とした攻撃の多くが金銭の直接的要求ないし機密情報の売買など
  - 暗号通貨が普及したことで，金銭の受渡しも足がつきづらくなり，サーバ内のデータなどを質にして金銭を要求するマルウェア（ランサムウェア）の被害報告も年々増加している

- 政治的な主張
  - 個人/団体に基づく政治的な思想が動機の根底にあり，Anonymousなどが知られている

- 単なる興味/怨恨/いたずらなど
  - 特に意味のある主張をすることもなく，遊びの延長のように単なる享楽として攻撃を繰り返すケースもゼロではない

etc.

Outline

- 攻撃者たちの目的と標的

- セキュリティの敗北史：ケーススタディ
  - KADOKAWAグループに対する大規模攻撃
  - 徳島県 半田病院に対するランサムウェア攻撃

ケーススタディ：KADOKAWAグループに対する大規模攻撃

概要（以下，2024/7/13現在での情報に基づく）：

- 2024年6月にKADOKAWAグループ内のデータセンターサーバが大規模な攻撃を受けた
  - 長期に渡るシステム障害やランサムウェアによる金銭的被害，関係者等の個人情報が流出するなど過去最大級の被害が発生
  - また，NewsPicks上でKADOKAWAグループと犯人間の身代金支払いなどに関するやり取りが報道され，報道の是非についても議論がなされている
- 公表情報[1]によれば，サーバをシャットダウンした後も犯人らが遠隔での起動＆感染拡大を図るなど執拗な攻撃を観測し，電源・通信ケーブルを物理的に抜線しなければならないほどであったようである

[1] 株式会社ドワンゴ：https://dwango.co.jp/news/5131439897051136/

ケーススタディ：KADOKAWAグループに対する大規模攻撃

考察

- ✓ 本来内部のものしか知らない情報がなぜ外部に漏れているのか
- ✓ また，報道がなされることで犯人を利する可能性はあるのか

- また，NewsPicks上でKADOKAWAグループと犯人間の身代金支払いなどに関するやり取りが報道され，報道の是非についても議論がなされている

❖公表情報[1]によれば，サーバをシャットダウンした後も犯人らが遠隔での起動＆感染拡大を図るなど執拗な攻撃を観測し，電源・通信ケーブルを物理的に抜線しなければならないほどであったようである

[1] 株式会社ドワンゴ：https://dwango.co.jp/news/5131439897051136/

ケーススタディ：KADOKAWAグループに対する大規模攻撃

考察

- ✓ 本来内部のものしか知らない情報がなぜ外部に漏れているのか
  - 情報提供者が金銭的あるいは何らかの対価を得ることで漏洩させた可能性
  - 何らかのコンプライアンス違反などに対する内部告発の可能性
- ✓ また，報道がなされることで犯人を利する可能性はあるのか

- また，NewsPicks上でKADOKAWAグループと犯人間の身代金支払いなどに関するやり取りが報道され，報道の是非についても議論がなされている

❖公表情報[1]によれば，サーバをシャットダウンした後も犯人らが遠隔での起動＆感染拡大を図るなど執拗な攻撃を観測し，電源・通信ケーブルを物理的に抜線しなければならないほどであったようである

[1] 株式会社ドワンゴ：https://dwango.co.jp/news/5131439897051136/

ケーススタディ：KADOKAWAグループに対する大規模攻撃

考察

- ✓ 本来内部のものしか知らない情報がなぜ外部に漏れているのか
  - 情報提供者が金銭的あるいは何らかの対価を得ることで漏洩させた可能性
  - 何らかのコンプライアンス違反などに対する内部告発の可能性
- ✓ また，報道がなされることで犯人を利する可能性はあるのか
  - 支払った身代金は犯行グループの活動資金（データが戻る保証もなし）
  - 一度払えば付け込まれる可能性も
- また，NewsPicks上でKADOKAWAグループと犯人間の身代金支払いなどに関するやり取りが報道され，報道の是非についても議論がなされている

❖公表情報[1]によれば，サーバをシャットダウンした後も犯人らが遠隔での起動＆感染拡大を図るなど執拗な攻撃を観測し，電源・通信ケーブルを物理的に抜線しなければならないほどであったようである

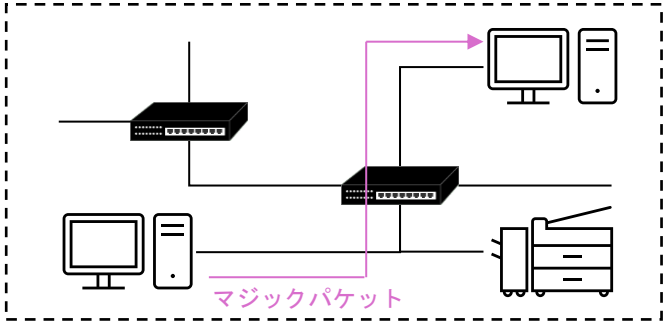
[1] 株式会社ドワンゴ：https://dwango.co.jp/news/5131439897051136/

ケーススタディ：KADOKAWAグループに対する大規模攻撃

考察

✓ Wake On Lan (WOL)を悪用？

- 同一ネットワーク上でシャットダウン・スリープしている端末に対して，マジックパケットと呼ばれる特殊なパケットを送付することで端末を遠隔起動するための仕組み
- これを悪用したランサムウェアも観測されている



✓ 使用する技術のセキュリティリスクを把握し，利便性と安全性はトレードオフであることを理解しておくことが極めて重要（さもなくば諸刃の剣となる）

❖公表情報[1]によれば，サーバをシャットダウンした後も犯人らが遠隔での起動＆感染拡大を図るなど執拗な攻撃を観測し，電源・通信ケーブルを物理的に抜線しなければならないほどであったようである

[1] 株式会社ドワンゴ：https://dwango.co.jp/news/5131439897051136/

ケーススタディ：徳島県 半田病院に対するランサム攻撃

概要（以下，2024/7/13現在での情報[2]，[3]に基づく）：

- 2021年10月にランサムウェア攻撃を受け，電子カルテ等の医療関係システムが停止したことで通常業務までの復旧に2か月を要した
  - 病院には厚生労働省からの注意喚起や対策についてのガイドラインは繰り返し出されていたが，その理解と具体的な対策に関しては対処できていなかった
  - 報道ではVPN装置の脆弱性が広く伝えられたが，様々な側面で課題があった
- 問題点は半田病院に対してのみならず，電子カルテシステム等の保守/運用にあたるシステムベンダに対しても知識・技術不足などが指摘されている

[2] つるぎ町半田病院：https://www.handa-hospital.jp/topics/2022/0616/index.html
[3] 情報処理学会・学会誌「情報処理」：https://note.com/ipsj/n/n184258249f0d#de8d785d-5359-439e-a544-6210f6dd2c13

ケーススタディ：徳島県 半田病院に対するランサム攻撃

指摘内容

- ✓ 病院内のシステム担当者は1人のみ
  - 院内の関係者だけで対処することは事実上困難な状況
- ✓ 地方ではシステムを納入するベンダが実際の保守，運用に携わることが多い
  - ただし，ベンダが必ずしも十分な知識を有しているとは限らない

- 病院には厚生労働省からの注意喚起や対策についてのガイドラインは繰り返し出されていたが，その理解と具体的な対策に関しては対処できていなかった
- 報道ではVPN装置の脆弱性が広く伝えられたが，様々な側面で課題があった

❖問題点は半田病院に対してのみならず，電子カルテシステム等の保守/運用にあたるシステムベンダに対しても知識・技術不足などが指摘されている

[2] つるぎ町半田病院：https://www.handa-hospital.jp/topics/2022/0616/index.html
[3] 情報処理学会・学会誌「情報処理」：https://note.com/ipsj/n/n184258249f0d#de8d785d-5359-439e-a544-6210f6dd2c13

ケーススタディ：徳島県 半田病院に対するランサム攻撃

指摘内容

- ✓ 半田病院の場合，ベンダから「インターネットに接続しておらず外部からサイバー攻撃を受けることはあり得ない」といった説明（閉域網の神話）を受け，信じていた
  - 実際にはVPN装置を介して，ベンダは外部からリモート接続していた
  - VPN装置の脆弱性は2年以上放置されていた
  - さらにその脆弱性が悪用され，認証情報が公開された後もVPN装置を利用し続けていた（ID/PWは運用者の名前に基づいた6文字からなるものだった）
- ✓ 必ずしもどちらにすべての責任があるといえる話ではなく，閉域網の神話を信じ杜撰な運用管理によって被害が拡大した例であるといえる

- 報道ではVPN装置の脆弱性が広く伝えられたが，様々な側面で課題があった

❖問題点は半田病院に対してのみならず，電子カルテシステム等の保守/運用にあたるシステムベンダに対しても知識・技術不足などが指摘されている

[2] つるぎ町半田病院：https://www.handa-hospital.jp/topics/2022/0616/index.html
[3] 情報処理学会・学会誌「情報処理」：https://note.com/ipsj/n/n184258249f0d#de8d785d-5359-439e-a544-6210f6dd2c13

まとめ

- 社会的にも大きく取り上げられた2つのサイバー攻撃例をとりあげ，その背景や専門家らの調査により指摘された事項などを概説した
- いずれも事業規模，形態は異なるがランサムウェア攻撃の標的となり甚大な被害を受けている
  - とりわけ半田病院の事例は，中小規模の組織では当てはまりうることが多く，病院に限った話ではなく，様々な業種の事業体が教訓を得るものであると考えられる
- 通信・半導体などの驚異的な性能向上に伴い，できることが多くなった一方で習得すべき事項も際限なく増加している
  - 自動車の所有に免許証や定期チェックが必要なように，すべての情報システム利用者が責任をもって理解を深める必要がある
  - 様々なステークホルダーが，組織の枠を超えた密な連携が不可欠な時代がきている